

CA Firm DPDPA Starter Checklist

Most CA firms don't have a tax knowledge problem — they have a client-document control problem. Work through these ten areas to bring your PAN, Aadhaar, ITR, bank, payroll and audit records under DPDPA-ready control.

PAN

Aadhaar

ITR

Bank Statements

Payroll

Google Drive

WhatsApp

Article-Staff Access

Client Rights

Old Files

How to use this: tick what you already do, and turn the unticked boxes into your next actions. Start with intake, access and retention — they remove the most risk for the least effort.

1 Client document intake

- ☐ Define ONE primary channel for receiving PAN, Aadhaar, ITR, bank statements and payroll (e.g. a secure portal or upload link).
- ☐ Tell clients at onboarding which channel to use — and ask them to avoid WhatsApp for sensitive documents.
- ☐ Collect only the documents the engagement actually needs (data minimisation).
- ☐ On receipt, move documents off WhatsApp/email into controlled storage, then delete the chat/attachment copy.
- ☐ Keep a simple log of what each client has sent, so you always know what you hold.

2 PAN / Aadhaar / bank statement handling

- ☐ Collect Aadhaar only when genuinely required; prefer masked Aadhaar where possible.
- ☐ Store identity and financial copies in access-controlled storage — not personal laptops or inboxes.
- ☐ Restrict who can open PAN/Aadhaar/bank files to staff who need them for the task.
- ☐ Avoid keeping extra photocopies or duplicate scans beyond what is needed.
- ☐ Securely destroy physical copies once digitised and no longer required.

3 Google Drive / OneDrive / cloud access

- ☐ Turn on multi-factor authentication (MFA) for every account that can open client folders.
- ☐ Use folder-level, role-based permissions — avoid 'anyone with the link' sharing.
- ☐ Review who has access to client folders at least twice a year.
- ☐ Remove access the same day a staff member changes role or leaves.
- ☐ Do not store client documents in personal cloud accounts.

4 Article assistant / intern access

- ☐ Give article assistants and interns access only to the clients they actively work on.
- ☐ Use need-based, time-bound access and revoke it when the assignment ends.
- ☐ Brief every new joiner on confidentiality and DPDPA basics before they touch client data.
- ☐ Keep a simple record of who can access which client folders.
- ☐ Disable accounts and revoke device/app access on the last working day.

5 Engagement letter / client notice

- ☐ Add a clause stating what client data you collect and why.
- ☐ State where data is stored, who may access it, and how long it is kept.
- ☐ Name a contact for client data questions and requests.
- ☐ Mention the vendors or tools that process client data on your behalf.
- ☐ Update the clause for DPDPA and re-issue it at renewal.

6 Vendor and software access

- ☐ List every tool/vendor that stores or processes client data — tax & GST software, payroll, cloud, IT support, outsourced teams.
- ☐ Prefer vendors that offer written terms covering data protection.
- ☐ Never share client files with vendors or outsourced teams over WhatsApp or personal email.
- ☐ Give each vendor access to the minimum data needed.
- ☐ Review the vendor list once a year.

7 Client communication & consent

- ☐ Get consent before adding clients to WhatsApp broadcast lists or marketing groups.
- ☐ Keep service messages (deadline/compliance reminders) separate from promotions and festival greetings.
- ☐ Give clients an easy way to opt out of newsletters and promotional messages.
- ☐ Don't reuse a client list from one service to market unrelated services without consent.
- ☐ Avoid exposing other clients' numbers — use broadcast, not open groups.

8 Old client file retention

- ☐ Set retention periods by document type, based on tax, audit, legal and professional needs.
- ☐ Separate 'must keep' (statutory) files from 'can delete' files.
- ☐ Schedule an annual review to archive or delete files past their period.
- ☐ Do not keep client data 'forever' by default.
- ☐ Write down your retention rules so the whole team applies them consistently.

9 Client data rights (access / correction / deletion)

- ☐ Be ready to tell a client what personal data you hold about them, on request.
- ☐ Have a process to correct inaccurate client details.
- ☐ Honour deletion/erasure requests for data you're not legally required to retain.
- ☐ Verify the client's identity before acting on a rights request.
- ☐ Log each request and your response as evidence of compliance.

10 Breach response

- ☐ Write a one-page response plan: who to call and what to do first.
- ☐ Know how to quickly lock a lost/stolen laptop, email, cloud folder or WhatsApp account.
- ☐ Keep a contact list (IT, partners, and a way to reach affected clients).
- ☐ Be ready to notify the Data Protection Board and affected clients as required.
- ☐ After any incident, record what happened and what you changed.